Runbook Problemas de Rede — Apex Group · Q2-2026

Versão consolidada · uso interno Apex NOC + Tier 2 Network

Runbook — Problemas de Rede & Infraestrutura

Versão: v4 · revisão semestral Q2-2026 · próxima revisão Q4-2026 **Owner:** Bruno (CTO) · **Maintainer:** Marina (Tier 2 Network Engineer) **Classificação:** documento confidencial — uso interno Apex NOC + Tier 2 Network + lideranças

Este runbook consolida procedimentos de troubleshooting de rede, identidade, capacity, escalação de incidentes e governança de postmortem da Apex Group. A audiência primária é o NOC interno (Diego em Tier 1, Marina em Tier 2 Network Engineering) e as lideranças que recebem postmortems (Bruno como CTO Tier 3, Carla como CFO em incidentes com impacto financeiro material). Toda a estrutura organizacional usa nomes próprios — Diego, Marina, Bruno, Lia, Carla — para resolver ambiguidades em logs e timelines.

O documento substitui a v3 (Q4-2025) e absorve as lições do postmortem da Black Friday 2025 (TKT-18). Cinco tickets âncora servem de base operacional ao longo dos capítulos: TKT-15 (Frota.io webhook silent fail), TKT-16 (CFTV Vila Mariana switch PoE), TKT-17 (Entra ID password rotation notification gap), TKT-18 (App Service B3 saturado na Black Friday) e TKT-20 (VPN site-to-site Loggi pós renewal de cert).

CAPÍTULO 1 — Visão arquitetural da rede Apex

Página 1 — Topologia high-level

1.1 Sites + footprint físico

A Apex Group opera sobre quatro sites físicos principais e uma região cloud primária. O footprint reflete a estrutura de 12 marcas + 340 lojas físicas + 8.000 colaboradores espalhados em sete estados brasileiros.

Sede São Paulo (Faria Lima). Dois andares ocupados em prédio comercial classe A, ~800 colaboradores em rotação de modelo híbrido (3 dias presenciais). Datacenter on-prem residual hospeda controladores de domínio AD (Active Directory legado), servidores de impressão, file server SMB e console de gerência do CFTV interno do prédio. A maior parte das cargas migrou para Azure entre 2023 e 2025, restando apenas o que tem dependência inevitável de presença local.

CD Cajamar (Centro de Distribuição principal). 38.000 m^2 de armazém + áreas administrativas + área de manutenção de frota. Operação contínua 24/7. Core de rede Cisco Catalyst 9500 redundante em par HA. WMS (Warehouse Management System) da Manhattan Associates hospedado em Azure, mas com conexão dedicada via ExpressRoute por motivos de latência (P95 ≤8ms para o WMS é requisito operacional para evitar paradas em conferência de doca).

CD Regional Recife. Failover parcial ativo desde Q3-2025. Atende lojas de Pernambuco, Paraíba, Alagoas e Bahia. Capacidade de continuidade de negócio limitada (não absorve 100% da carga do Cajamar — apenas operação degradada de marcas Apex Mercado e Apex Logística por até 14 dias caso o Cajamar fique indisponível).

340 lojas físicas distribuídas. São Paulo (180), Rio de Janeiro (54), Minas Gerais (28), Bahia (22), Paraná (24), Rio Grande do Sul (18), demais estados (14). Cada loja segue um branch padrão: 1 FortiGate 100F, 1 FortiSwitch 124F-POE, 3 FortiAPs 431F, 12 câmeras IP Hikvision em média e 5 PDVs Gertec MP-2100 TH em média. A padronização rigorosa é o que permite operar 340 sites com uma equipe Tier 2 Network de 6 engenheiros — qualquer desvio do branch padrão exige aprovação de Marina.

Cloud Azure. Região primária **Brazil South** (São Paulo). Região DR **Brazil Southeast** (Rio de Janeiro), ativada exclusivamente para failover de cargas críticas Tier 0/1. A geografia dual-region reduz o risco de evento sistêmico regional (e.g., apagão prolongado, ataque coordenado a infraestrutura).

1.2 Conectividade entre sites

A conectividade é estruturada em camadas, com priorização clara de tráfego business-critical sobre administrativo.

Conexão	Capacidade	Tipo	BGP ASN Apex
Sede SP ↔ Azure Brazil South	1 Gbps	ExpressRoute primário · Equinix SP4 · Provider Embratel	65010
CD Cajamar ↔ Azure Brazil South	1 Gbps	ExpressRoute primário · Equinix SP4 · Provider Embratel	65011
CD Recife ↔ Azure Brazil Southeast (DR)	200 Mbps	ExpressRoute Standard · Equinix RJ2 · Provider Algar	65012
340 lojas ↔ Azure Hub (Virtual WAN)	Site-to-site IPsec	Túneis individuais · cada loja como spoke do hub	—
Lojas ↔ link backup	4G/LTE	Failover SD-WAN automático via FortiGate	—

Os túneis VPN site-to-site das lojas convergem em um **Azure Virtual WAN hub** (`vwan-apex-brsouth`) que agrega aproximadamente 340 túneis ativos simultaneamente. O hub roteia o tráfego inter-loja (caso necessário) e o tráfego loja→Azure (apps, ERP, ML serving, etc) com isolamento por VLAN e rotas controladas por route tables do Virtual WAN.

Em todas as 340 lojas há um link 4G/LTE de backup. O FortiGate executa SD-WAN com política de failover automática: queda do link primário ativa o backup em <30 segundos. Em modo backup, o tráfego é seletivamente limitado — apenas PDV/Cielo, ERP read-only e telemetria continuam funcionais. WiFi cliente, CFTV upload e BI são desligados para preservar banda.

1.3 Parceiros conectados

A Apex Group mantém integração com cinco categorias de parceiros estratégicos, cada um com modelo de conectividade próprio. A escolha do modelo de cada conexão considera três dimensões: (1) volume e criticidade de tráfego, (2) requisitos regulatórios (PCI-DSS, Bacen, LGPD), e (3) custo de manutenção operacional ao longo do contrato.

Cielo (adquirência). Extranet via certificado TLS mútuo (mTLS). Cada PDV apresenta certificado x.509 emitido pela Issuing CA da Cielo durante o handshake TLS contra `*.cielo.com.br`. Não há VPN — toda a comunicação roda sobre internet pública com criptografia mTLS, dentro do envelope PCI-DSS auditado anualmente. O escopo PCI da Apex foi reduzido em 2024 com a adoção de Cielo P2PE (Point-to-Point Encryption), o que limitou os controles compensatórios a um conjunto bem definido de hosts (gateway de pagamento + servidores de reconciliação financeira). Esta arquitetura é mandatária para todos os PDVs da rede e foi consolidada em política Apex aprovada pelo Conselho em Q3-2024.

Frota.io (roteirizador last-mile). Webhook REST + OAuth2 client credentials. O TMS interno (`app-tms-prod` em Azure App Service) chama `POST https://api.frota.io/v1/orders` autenticado por OAuth2 com Service Principal `sp-frota-tms-prod`. Este parceiro é o protagonista do TKT-15 e a integração serve como referência para todas as integrações REST third-party da Apex (padrão de auth, retry, observability). Volume típico: 2.800 pedidos/dia em dias normais, picos de 8.400/dia em datas comerciais — todos processados em janelas de 2-5 minutos.

Loggi (last-mile complementar). VPN site-to-site IPsec dedicada entre FortiGate do CD Cajamar e Cisco ASA 5516-X do lado Loggi. Subnets protegidas: Apex `10.50.0.0/16` ↔ Loggi `172.18.4.0/22`. Este parceiro é o protagonista do TKT-20. Apesar de a maior parte das integrações last-mile hoje rodar via API REST sobre internet pública, a Loggi mantém modelo VPN por exigência contratual — historicamente, a Loggi tinha exposure regulatório por hospedar dados sensíveis em seu lado, e a VPN aderia ao framework de segurança que minimizava esse risco. A migração para modelo REST está em discussão para o ciclo contratual 2027-2030.

TOTVS (ERP cloud). ExpressRoute peering cross-cloud (TOTVS hospedado em própria estrutura Azure). BGP ASN 65020 Apex peering contra ASN TOTVS dedicado. Latência P95 ≤5ms sustentada — requisito para que NF-e emitidas no PDV cheguem ao ERP em janela operacional. A integração TOTVS é a mais sensível em latência da Apex, dado que o ERP carrega ~640 transações/segundo durante picos de NF-e. O peering ExpressRoute foi negociado com cláusula contratual de SLA agregado (Apex Embratel + Microsoft + TOTVS), o que simplificou a triagem de incidentes — qualquer queda de latência além do threshold dispara o ticket Premier Support no provider responsável diretamente.

Bacen PIX SPI. Circuito dedicado com certificado ICP-Brasil. Conexão direta com a infra do Sistema de Pagamentos Instantâneos do Banco Central. Operada por equipe de Pagamentos (out-of-scope deste runbook), mas Marina mantém visibilidade da disponibilidade para diagnóstico cruzado. Quando há indisponibilidade percebida em PIX no canal de e-commerce ou loja, a primeira validação é se o problema está no link Bacen ou em algum componente Apex (gateway, ERP, integration layer). O Tier 2 Apex acompanha dashboard publicado pela própria Bacen (status.spi.bcb.gov.br equivalente) e correlaciona com sintomas internos.

Página 2 — Stack de tecnologias

A padronização rigorosa da stack é o pilar que sustenta operações em 340 sites com equipe enxuta. Qualquer equipamento fora dos modelos abaixo exige aprovação Bruno + documentação no NetBox como exceção justificada.

2.1 Edge das lojas

Camada	Equipamento	Quantidade	Versão firmware mínima
Firewall + SD-WAN	Fortinet FortiGate 100F	340 (1 por loja)	FortiOS 7.4.6
Switch acesso PoE	Fortinet FortiSwitch 124F-POE	340 (1 por loja)	FortiSwitchOS 7.4.2
Access Point WiFi 6	Fortinet FortiAP 431F	1020 (3 por loja)	FortiAP 7.4.3
Câmeras CFTV (IP PoE)	Hikvision DS-2CD2143G2-I	~4080 (12 por loja média)	Firmware V5.7.21
PDV (POS)	Gertec MP-2100 TH	~1700 (5 por loja média)	—

A escolha pela linha Fortinet para edge se justifica por três fatores: (1) Security Fabric integrada — FortiGate + FortiSwitch + FortiAP gerenciados pelo mesmo console FortiCloud com push de config consistente; (2) SD-WAN nativo no FortiGate sem licença adicional para failover 4G/LTE; (3) Suporte robusto à zona de TI corporativa BR via parceiro regional (Westcon-Comstor) com SLA de RMA em 24h úteis para os equipamentos cobertos.

A versão de firmware mínima é monitorada via FortiCloud. Equipamentos abaixo da baseline recebem upgrade automático na janela quarta 04h-06h. Equipamentos críticos (CD Cajamar, sede SP) seguem ciclo separado coordenado por Marina.

2.2 Core sede + CD

Camada	Equipamento	Local
Core switch	Cisco Catalyst 9500-48Y4C	Sede SP + CD Cajamar
Distribution	Cisco Catalyst 9300-48UXM	Sede SP (×4) + CD (×8)
Firewall perimetral	Palo Alto PA-3260 HA pair	Sede SP + CD
Load balancer	F5 BIG-IP i2800	Sede SP (LTM + ASM)
ExpressRoute MSEE	Equinix SP4 (provider Embratel)	Edge SP

O core nas localizações estratégicas (sede SP, CD Cajamar) usa Cisco por razão histórica — a infraestrutura existente desde 2018 foi mantida no upgrade de 2024 dado o investimento prévio e o conhecimento da equipe. O firewall perimetral Palo Alto PA-3260 em HA pair faz inspeção L7 + IPS +

URL filtering para todo tráfego que sai da rede corp via internet (não via ExpressRoute). Para tráfego cloud Apex→Azure, o egresso é direcionado pelo ExpressRoute primário com fallback para ExpressRoute secundário em caso de falha.

2.3 Azure landing zone

A landing zone Azure foi desenhada seguindo o blueprint **Cloud Adoption Framework (CAF)** da Microsoft, com adaptações para a realidade Apex (40 subscriptions ativas, ~2.3 PB de dados gerenciados, ~4.500 recursos rodando em produção).

Estrutura hierárquica de Management Groups:

```
Tenant Root
├── apex-platform        (subscriptions de plataforma: identity, networking, monitoring)
│   ├── apex-identity    (Entra ID, ADDS, governance)
│   ├── apex-network     (Virtual WAN, Hub, peering)
│   └── apex-observability  (Log Analytics, Sentinel, Application Insights)
├── apex-workloads       (subscriptions de aplicação)
│   ├── apex-mercado     (cargas Apex Mercado)
│   ├── apex-tech        (cargas Apex Tech)
│   ├── apex-moda        (cargas Apex Moda — incluindo apexmoda.com.br)
│   ├── apex-casa        (cargas Apex Casa)
│   └── apex-logistica   (cargas Apex Logística — incluindo TMS)
└── apex-sandbox         (dev/test isolado)
```

Hub VNet (`vnet-hub-brsouth`) ocupa o espaço 10.100.0.0/16 e hospeda o **Azure Firewall Premium**, o **ExpressRoute Gateway** e o **VPN Gateway** que termina os túneis das 340 lojas (via Virtual WAN). Toda a comunicação entre workloads (apex-moda → apex-mercado, por exemplo) é forçada via Azure Firewall com inspeção L7, salvo exceções aprovadas pelo CTO.

DNS privado interno: zona `corp.apex.local` resolvida via Azure Private DNS, com forwarders configurados nos DCs on-prem para resolver registros AD legados. A resolução cross-site é uniforme — `app-tms-prod.corp.apex.local` resolve idêntico para colaborador em Recife, sede SP ou loja de Vila Mariana.

Identity: tenant Entra ID `apex.onmicrosoft.com` com domínios federados (`apex.com.br`, `apexmercado.com.br`, `apextech.com.br`, etc) sincronizado com o AD on-prem via **Azure AD Connect cloud sync** (substituiu o Connect Sync v1 legado em Q3-2025, eliminando o requisito de servidor dedicado on-prem para o agente de sync).

Página 3 — SLAs + ownership matrix

3.1 Tiers de SLA por classe de site

A diferenciação de SLA por tier reflete o impacto de negócio de cada classe de site. Um minuto de indisponibilidade do gateway PIX SPI tem impacto incomparavelmente maior do que um minuto de indisponibilidade de uma loja de bairro.

Tier	Sites	SLA mensal	RTO objetivo	RPO objetivo
Tier 0	Bacen PIX SPI, gateway pagamentos	**99.99%**	<5 min	0 (sync)
Tier 1	Sede SP, ExpressRoute primário	**99.99%**	<15 min	<5 min
Tier 2	CD Cajamar	**99.95%**	<30 min	<15 min
Tier 3	CD Regional Recife	**99.9%**	<2 h	<30 min
Tier 4	Lojas físicas (340)	**99.5%**	<4 h	<1 h

O SLA de loja Tier 4 considera operação degradada aceitável com link 4G/LTE backup. Em prática, uma loja "sem PIN pad sem fila" (PDV funcional com Cielo via 4G) opera dentro do SLA mesmo que o link primário esteja down. Já a perda total de qualquer conectividade (primário + 4G simultâneos) é configurada para gerar alerta P1 imediato.

Os números de SLA são monitorados em **Azure Monitor + Grafana** com dashboards públicos para a equipe interna. Carla (CFO) recebe relatório mensal de aderência aos SLAs por tier, e desvios materiais (e.g., SLA Tier 1 caindo para 99.95%) entram em agenda do Comitê Executivo.

3.2 Janelas de manutenção padrão

A definição de janelas é parte crítica da governança operacional — sem janelas previsíveis, mudanças se acumulam e elevam o risco a cada deploy.

Sede + CD: terças-feiras 03h-05h BRT (notificação D-7). Mudanças com impacto observável devem ter rollback testado em ambiente de pré-produção que espelha a topologia exata.

Lojas (340 sites): quartas-feiras 04h-06h BRT (notificação D-3 via push para gerentes via HelpSphere). A janela curta de 2h é proposital — força a equipe Tier 2 a planejar mudanças realmente atomic, com fallback automatizado se a janela não fechar a tempo da abertura comercial.

Emergencial: qualquer horário com aprovação explícita Bruno (CTO) + comunicado para stakeholders <2h antes do início. Aplicado em duas situações: (a) vulnerabilidade de segurança crítica (CVSS ≥9.0) com PoC pública sem mitigação alternativa; (b) mitigação ativa de incidente Sev1 em curso.

3.3 Matriz de ownership (RACI compacto)

Domínio	Responsável (R)	Aprovador (A)	Consultado (C)
LAN loja (switch + AP)	Marina (Tier 2)	Bruno	Vendor Fortinet
WAN + ExpressRoute	Marina (Tier 2)	Bruno	MS Premier Support
VPN parceiros	Marina (Tier 2)	Bruno	Contraparte parceiro
Identity (Entra ID)	Bruno (CTO Tier 3)	Bruno	MS Identity Support
Apps Azure (App Service, AKS)	Bruno (CTO Tier 3)	Bruno	DevOps interno
CFTV + automação	Marina (Tier 2)	Bruno	Vendor Hikvision

A escolha de ter Bruno como responsável direto (R) por Identity + Apps reflete uma decisão consciente — a complexidade do tenant Entra ID Apex (40 subscriptions, 200+ Conditional Access policies, integração federated com 12 domínios) e a maturidade ainda em construção da equipe SRE (em formação) tornam imprudente delegar plenamente o domínio até que squad de SRE atinja senioridade requerida. Plano de transição prevê passagem de R do Identity para SRE Lead em Q4-2026.

CAPÍTULO 2 — Troubleshooting LAN de loja

Página 4 — Switch PoE falhando

4.1 Cenário âncora — TKT-16 (CFTV hortifruti Vila Mariana)

Quatro câmeras Hikvision do setor de hortifruti da loja Vila Mariana ficaram offline por três dias úteis consecutivos. As demais câmeras da mesma loja (oito unidades cobrindo entrada, caixas, açougue, padaria, vinhos e estoque) permaneceram operacionais durante o período. A regulação interna de segurança patrimonial Apex exige cobertura mínima de 80% das áreas de venda — quatro câmeras a menos colocou a loja a 67%, abaixo do limite, mas sem caracterizar urgência operacional imediata.

Diego (Tier 1) abriu o ticket após o sistema de gravação central (NVR no CD Cajamar) reportar gap de 72h consecutivas nas streams das quatro câmeras alvo. A suspeita inicial foi cabo rompido em manutenção recente de gesso no setor de hortifruti, mas o diagnóstico final apontou degradação do PoE budget do FortiSwitch local.

4.2 Procedimento Tier 1 (Diego) — coleta de evidência

A coleta padronizada de evidência reduz drasticamente o tempo de Tier 2 — uma boa coleta inicial faz Marina resolver em 15 minutos o que uma coleta ruim faria levar horas.

1. **Verificar status físico do switch local na loja.** Diego acessa via HelpSphere o tópico "Status do site" e visualiza o painel do FortiGate local, que reporta status agregado dos equipamentos da Security Fabric (FortiSwitch, FortiAPs). Quando o painel apresenta `Healthy`, prossegue para o passo 2. Quando reporta `Degraded` ou `Offline`, abre ticket prioritário automaticamente.
2. **Solicitar gerente da loja inspeção visual do rack.** O gerente é orientado a fotografar três pontos: o LED frontal do FortiSwitch (deve estar verde sólido + verde piscando em portas ativas), a temperatura do rack (sensor digital fixado próximo) e a integridade dos cabos no patch panel.
3. **Coletar log do FortiSwitch acoplado.** Via console do FortiGate (autenticação centralizada via FortiCloud), Diego executa:

   ```
   diagnose switch-controller switch-info port-stats <port-id>
   ```

   A saída revela contadores de pacotes TX/RX, erros (CRC, undersize, oversize), drops e taxa de utilização da porta.
4. **Identificar portas que alimentam câmeras alvo.** O sistema de inventário NetBox (`netbox.apex.local`) mantém o mapeamento de cada câmera para sua porta no FortiSwitch local. Diego cruza o ID da câmera (etiqueta física + entry no Hikvision iVMS) com a porta correspondente.
5. **Decidir escalação.** Se o LED da porta está apagado mas a câmera está fisicamente conectada e energizada, o diagnóstico aponta caso PoE falho. Diego escala para Marina (Tier 2) com todo o material coletado acima.

4.3 Procedimento Tier 2 (Marina) — diagnóstico avançado

Marina assume o ticket via FortiCloud SSO. O fluxo padrão segue cinco passos.

1. **SSH no FortiGate da loja**. O acesso é federado via Entra ID — Marina autentica com sua conta corporativa + MFA, recebe token de sessão e o FortiGate valida via RADIUS contra o servidor IAS interno:

   ```
   ssh marina.silva@10.99.<store-id>.1
   ```

O range 10.99.x.0/24 é o pool de management dedicado para acesso administrativo às lojas.

2. **Inspecionar PoE budget vs consumo.**

```
diagnose switch poe status
```

Saída típica:

```
 FortiSwitch S124FP12000247
Power Budget: 370W
Power Consumed: 358W (96.7%)
Power Available: 12W
Class 4 (PoE+, 30W max): 8 ports active
Class 6 (PoE++, 60W max): 2 ports active
```

3. **Analisar saturação.** Quando o consumo passa de 95% do budget, novas requisições de PoE são negadas — o switch entra em modo defensivo para proteger o supply interno. Câmeras Hikvision DS-2CD2143G2-I solicitam Class 4 (até 30W) na inicialização e operam normalmente em ~12W. Se quatro câmeras entram em fault simultâneo, é provável que o switch tenha cruzado limiar e priorizado outras portas ao restartar.
4. **Listar portas afetadas.** O comando granular revela o estado por porta:

```
diagnose switch poe port-status <interface>
```

Estados possíveis: `delivering-power` (operando normal), `searching` (negociando), `fault` (falha permanente — porta queimou ou dispositivo conectado puxa mais do que classe permite), `disabled` (administrativamente desabilitado).

5. **Coletar conexões físicas no patch panel.** Marina consulta o diagrama atualizado do site no NetBox e cruza com fotos enviadas por Diego/gerente. Se cabo rompido (obra de gesso recente é causa comum), agenda refazimento via OS para `infraestrutura@apex.com.br`.

4.4 Critérios de troca emergencial do switch

A decisão de trocar versus aguardar janela planejada deve seguir critérios objetivos para evitar overreaction (custo + risco de cabling errado) e underreaction (degradação prolongada).

- **≥30% das portas em estado `fault`.** Indica falha sistêmica do supply PoE ou da placa-mãe.
- **Power budget bate o teto recorrentemente.** Três ocorrências em sete dias caracterizam degradação progressiva — provavelmente capacitores envelhecendo no supply interno.
- **Temperatura interna >65°C.** O sensor é exposto por `diagnose switch thermal`. Sustentado >65°C reduz vida útil de componentes magnéticos pela metade a cada +10°C.

- **CPU sustentada >80% por >2h.** Indica memory leak no FortiSwitchOS, que escalaria para outage completo em horas adicionais. Diagnóstico: rodar `diagnose switch debug memory` antes da troca para coletar evidência para abertura de ticket TAC Fortinet.

4.5 Janela de troca

Severidade	Janela	Aprovação
Emergencial (loja down)	Imediata	Marina (Tier 2)
Planejada (degradação)	Quarta 04h-06h	Marina + GR da loja
Refresh tecnológico	Trimestral (sprint NOC)	Bruno (CTO)

4.6 Casos arquivados de troca de switch (último ano)

A revisão trimestral do programa de operações de campo cruza os casos de troca de switch com a base instalada. Os números abaixo são informativos e ajudam a calibrar o estoque de spares + janela de RMA Fortinet.

Trimestre	Trocas emergenciais	Trocas planejadas	Trocas refresh	Total
Q3-2025	4	11	28	43
Q4-2025	7	9	30	46
Q1-2026	3	12	32	47
Q2-2026 (parcial)	2	6	18	26

O pico de trocas emergenciais em Q4-2025 (7 ocorrências) correlaciona com sazonalidade — Black Friday + datas comerciais aumentam carga PoE nas lojas (mais câmeras temporárias ativadas para cobertura de segurança em vitrines, mais APs para tráfego de cliente no WiFi público). A análise levou ao ajuste do dimensionamento PoE para janela sazonal: lojas Tier 4 alvo recebem upgrade temporário para FortiSwitch 148F-POE (520W budget vs 370W do 124F) entre meados de novembro e meados de janeiro.

Página 5 — VLAN segregation

5.1 Modelo padrão de VLANs por loja

A segmentação VLAN por categoria de tráfego é elemento crítico do programa de zero-trust interno da Apex. Cada loja segue o modelo padrão abaixo, com customizações documentadas apenas em casos excepcionais (todos rastreados no NetBox como Site Exception).

VLAN ID	Nome	Subnet template	Uso	Acesso à internet?	Acesso ao core?
10	`vlan-mgmt`	10..10.0/24	Gestão APs/switches/FortiGate	Não	Sim (gerência)
20	`vlan-pos`	10..20.0/24	PDV + impressora fiscal + balança	Restrito (Cielo, SEFAZ)	Sim (ERP)
30	`vlan-cftv`	10..30.0/24	Câmeras IP + NVR local	Não	Sim (NVR central)
40	`vlan-corp`	10..40.0/24	Notebooks colaboradores	Sim (filtrado)	Sim (corp apps)
50	`vlan-iot`	10..50.0/24	Sensores (temperatura câmara fria, RFID)	Não	Sim (IoT hub)
100	`vlan-wifi-cliente`	172..0.0/22	WiFi cliente final	Sim (NAT only)	**Não** (isolado)

O placeholder `<store>` é substituído pelo store_id de três dígitos (e.g., loja 047 vira `10.47.20.0/24`). Como Apex tem 340 lojas, o range 10.001-10.340 cobre toda a rede com folga.

5.2 Regras de firewall padrão (FortiGate policy template)

As regras abaixo são pushed automaticamente em qualquer FortiGate novo de loja a partir do template `policy-loja-padrao.cfg`. Qualquer divergência exige documentação justificativa.

- `vlan-pos` → Cielo `*.cielo.com.br` (TLS 443) **ALLOW**
- `vlan-pos` → SEFAZ estado da loja (TLS 443) **ALLOW**
- `vlan-pos` → ERP `erp.apex.local` **ALLOW**
- `vlan-pos` → qualquer outro destino **DENY** (zero-trust strict)
- `vlan-wifi-cliente` → Internet via NAT, com filtro UTM (categoria adult/malware **DENY**)
- `vlan-wifi-cliente` → qualquer VLAN interna **DENY** (isolamento total)

5.3 Erros comuns + remediation

A tabela abaixo consolida os erros que mais frequentemente chegam ao Tier 1 e a abordagem padrão de resolução.

Sintoma	Causa provável	Correção
Cliente reclama WiFi lento (cliente final)	Saturação canal 2.4GHz · APs sem band steering	Habilitar band steering no SSID + reset clientes
PDV não conecta SEFAZ	Policy `vlan-pos` →SEFAZ retorna `Deny` ; checar se IP da SEFAZ mudou	Atualizar object FQDN do FortiGate; pull manual `diagnose firewall fqdn list`
CFTV não grava no NVR central	Bloqueio inter-VLAN ou MTU mismatch	Validar policy `vlan-cftv` → `vnet-hub` e fragmentação RTSP
Notebook corp não acessa ERP via WiFi	AP autenticou em SSID cliente (não corporativo)	Forçar profile EAP-TLS · reemitir cert do device

Cada uma dessas correções tem playbook específico no FreshService Knowledge Base (privilégio de leitura para Tier 1) e procedimento de validação pós-correção (smoke test que confirma que a remediation efetivou).

5.4 Auditoria semestral de segmentação VLAN

A segmentação VLAN tem tendência a degradar ao longo do tempo. Cabos plugados em portas erradas, configurações ad-hoc por equipe de campo, exceções aprovadas que não foram revertidas após o evento — todos esses fatores erodem a postura zero-trust desenhada.

Para combater isso, a Apex roda auditoria semestral programada em janeiro e julho, conduzida por Marina + um auditor externo (consultoria contratada). O processo:

1. Pull automatizado de configuração de TODOS os FortiSwitches via FortiCloud REST API.
2. Comparação byte-a-byte com o template `vlan-loja-padrao.cfg` (golden config).
3. Identificação de divergências por loja (porta atribuída a VLAN incorreta, VLAN não-padrão criada, ACL customizada não-aprovada).
4. Cross-reference com tickets NetBox para validar se a divergência tem justificativa formal aprovada.
5. Relatório consolidado para Bruno + Carla com taxa de aderência por região + recomendação de remediation.

Resultados das últimas três auditorias:

Auditoria	Aderência média	Divergências sem justificativa	Tempo médio para remediation
Janeiro 2025	84.2%	218 (5.7% da base)	47 dias
Julho 2025	91.5%	132 (3.4% da base)	32 dias
Janeiro 2026	96.1%	64 (1.6% da base)	18 dias

A tendência de melhoria reflete três investimentos: padrão de change management apertado (todo push de config exige justificativa em NetBox antes da aplicação), automação de detecção de drift (alerta semanal para Marina sobre divergências detectadas), e treinamento contínuo da equipe de campo regional sobre disciplina de configuração.

Página 6 — Cabeamento + patch panel

6.1 Padrões de cabeamento Apex

A definição de padrão de cabeamento foi reformulada em Q4-2024 após auditoria identificar 23% das lojas com cabling fora de padrão (mix de Cat5e e Cat6 não-blindado em ambientes industriais ruidosos como CD Cajamar, gerando flapping de link e dropped packets). O padrão atual:

Vertical (entre andares): fibra OM4 LC-LC duplex 50/125 micrometros, suportando 10G/40G. Justificativa: trajetos verticais cruzam shafts com cabeamento elétrico de potência (PDUs de elevador, iluminação principal) — fibra elimina vulnerabilidade a EMI/RFI que cabos de cobre teriam.

Horizontal (rack→tomada): Cat6A blindado (S/FTP) garantindo até 100m para PoE++ 60W. Justificativa: câmeras 4K Hikvision (próxima geração planejada para Q1-2027) demandam até 25W sustentado, e o padrão de aterramento do S/FTP elimina ground loops em prédios antigos.

Cordões de equipamento: Cat6A patch cords com codificação por cor seguindo o esquema **azul=pos, vermelho=cftv, verde=corp, amarelo=mgmt, branco=iot**. A codificação acelera diagnóstico — qualquer técnico em campo identifica visualmente em 5 segundos qual cordão pertence a qual VLAN.

Labeling: etiqueta dupla face em cada ponta com formato `<rack-id>.<u>-<porta> ↔ <tomada-id>`. Etiquetas geradas via impressora Brother PT-P710BT calibrada (substituição de etiqueta manual feita à caneta, fonte recorrente de erro humano nos diagnósticos anteriores).

6.2 Rotina de teste (mensal por loja, trimestral por CD)

A rotina de teste é parte do programa de manutenção preventiva e busca evidência de degradação **antes** que vire incidente operacional.

1. Validar continuidade com Fluke MicroScanner ou equivalente — teste BERT (Bit Error Rate Test) pass/fail.
2. Verificar atenuação por canal: >30dB para fibra OM4 caracteriza problema — refazer fusão ou trocar o segmento.
3. Atestar PoE delivery medindo tensão na tomada (45-57V DC esperado para 802.3bt).
4. Cross-reference com base de inventário de cabos no FreshService (ativo `CAB-<store>-<id>`).
5. Reprovados: gerar OS para `infraestrutura@apex.com.br` com fotos + diagnóstico.

6.3 Padrão de identificação de patch panel

Patch panel é a fonte mais comum de incidente Tier 1 mal escalado. Quatro regras inegociáveis:

1. **NUNCA** remexer cordão sem etiqueta legível — abrir OS antes para validar o mapeamento atual.
2. **NUNCA** reutilizar porta queimada sem trocar o conector RJ45 + retesta com Fluke.
3. Após qualquer mudança física, atualizar o diagrama do site no NetBox imediatamente. A latência entre mudança física e atualização do NetBox é monitorada — sites com gap >24h entram em lista de exceção do GR.
4. Validar com `show interface status` no FortiSwitch que a porta enxergou o link após mudança.

6.4 Falhas frequentes documentadas (últimos 24 meses)

Falha	Frequência (24m)	Causa-raiz típica
Cabo rompido durante obra civil	~12 ocorrências/ano	Falta de marcação do trajeto + caderno de obra ignorado
Conector RJ45 mal crimpado	~30 ocorrências/ano	Cordão feito em campo sem alicate calibrado
Atenuação alta em fibra	~5 ocorrências/ano	Fusão envelhecida + sujeira no ferrule
Aterramento ausente (S/FTP)	~8 ocorrências/ano	Rack sem barra de equipotencialização instalada

A análise de tendência aponta que conectores RJ45 mal crimpados representam 50% dos incidentes de cabeamento. Resposta da equipe: pedido de compra de 12 alicates Klein VDV226-110-SEN calibrados para distribuição em hubs regionais (em fluxo de aprovação Carla, Q3-2026).

6.5 Plano de melhoria de cabeamento Q3-Q4 2026

A maturidade da infraestrutura de cabeamento ainda está aquém do nível desejado para suportar a próxima geração de capacidade (câmeras 4K, APs WiFi 7, IoT em escala). O plano Q3-Q4 2026 prevê três frentes:

Frente 1 — Substituição de cabling legacy. Aproximadamente 80 lojas ainda operam com mix Cat5e + Cat6 não-blindado (legado pré-2020). Plano de substituição com prioridade por: (a) lojas em CDs urbanos densos (Apex Mercado Vila Mariana, Apex Tech Berrini); (b) lojas próximas a fontes de EMI/RFI (Apex Casa Itaim sobre estação Metrô CPTM); (c) demais lojas no ciclo natural de manutenção predial. Capex estimado: R$ 480.000.

Frente 2 — Reforço de patch panels. Auditoria de Q1-2026 identificou que 47% das lojas têm patch panels com etiquetagem ilegível ou ausente. Plano: equipamento Brother PT-P710BT em todas as filiais regionais para refazer etiquetagem padronizada. Capex: R$ 38.000.

Frente 3 — Programa de treinamento técnicos de campo. Apex contrata serviços de técnico de campo via 4 parceiros regionais. A homogeneidade do nível técnico é heterogênea — alguns parceiros mantêm equipe certificada Fortinet (NSE 4-5), outros operam com auxiliares treinados internamente apenas. Plano: certificar minimamente NSE 4 em todos os técnicos que atendem lojas Tier 4. Custo (compartilhado com parceiros): R$ 64.000.

Página 7 — Procedimento de troca de switch (emergencial vs planejada)

7.1 Decision tree

```
Switch falhou? →
  ├─ Loja inteira down? → EMERGENCIAL (vide 7.2)
  ├─ Setor crítico down (PDV)? → EMERGENCIAL
  ├─ Setor não-crítico down (CFTV apenas)? → PLANEJADA próxima quarta
  └─ Degradação intermitente? → INVESTIGAR antes de trocar
```

O caminho “INVESTIGAR antes de trocar” merece destaque — trocar switch sem confirmar root cause leva a recurrence (o problema reaparece dias depois no mesmo site). A regra é: trocar apenas com evidência objetiva de falha permanente. Degradação intermitente sem causa-raiz identificada exige análise de logs + monitoramento adicional antes da troca.

7.2 Procedimento emergencial (RTO objetivo <4h)

A timeline abaixo é a target operacional, alcançada em ~85% dos casos. Os outliers (15%) são tipicamente lojas remotas onde courier de spare leva mais tempo (operação Apex sem hub regional próximo).

1. **T+0:** abertura de ticket P1 no HelpSphere (Diego) → escalação imediata para Marina (paging push).
2. **T+10min:** Marina valida diagnóstico via FortiGate Cloud + decide pela troca.
3. **T+15min:** acionar courier de spare via parceiro de logística TI (estoque central no CD Cajamar).
4. **T+20min:** comunicar gerente da loja + agendar técnico de campo (parceiro regional pré-cadastrado).
5. **T+2h:** técnico chega na loja com switch novo, transceivers e cabos.
6. **T+2h15:** técnico desliga switch antigo, identifica todos os cordões com etiqueta nova provisional.
7. **T+2h30:** instalação física do switch novo + power on.
8. **T+2h45:** push da config do FortiGate (template `switch-loja-padrao.cfg`) via FortiCloud.
9. **T+3h:** validação ponta-a-ponta (CFTV grava, PDV transaciona, WiFi conecta).
10. **T+3h15:** sign-off Marina + atualização NetBox + RMA do switch antigo para Fortinet.

7.3 Procedimento planejado (janela quarta 04h-06h)

1. **D-3:** anunciar manutenção via HelpSphere + push para gerente de loja.
2. **D-1:** spare empacotado + roteiro do técnico finalizado.
3. **D-day 04h:** técnico chega na loja (loja fechada).
4. **04h15-05h45:** troca + config + validação.
5. **05h45-06h:** smoke test loja (Diego acompanha via dashboard remoto).
6. **06h:** sign-off + abertura normal da loja.

7.4 Estoque mínimo de spares

Equipamento	Spare mínimo	Localização
FortiSwitch 124F-POE	12 unidades	CD Cajamar (cofre TI)
FortiGate 100F	8 unidades	CD Cajamar (cofre TI)
FortiAP 431F	20 unidades	CD Cajamar + 4 hubs regionais (PA, BA, RS, PR)
Transceivers SFP+ 10G LR	30 unidades	CD Cajamar
Patch cords Cat6A 3m	200 unidades	CD Cajamar + lojas (kit emergência 5un/loja)

O dimensionamento de spares foi calculado considerando histórico de falhas + tempo de RMA Fortinet (24h úteis para 100F/124F-POE, 5 dias úteis para 431F). A revisão é trimestral — qualquer marca de utilização >50% do estoque dispara reorder automático.

CAPÍTULO 3 — Troubleshooting WAN e VPN

Página 8 — VPN site-to-site Loggi (TKT-20 âncora)

8.1 Cenário

A VPN IPsec site-to-site entre a Apex Logística e a Loggi caiu após a renovação programada do certificado X.509 do lado Loggi em 28/04 (Q2-2026). O sintoma observado nos logs do FortiGate do CD Cajamar foi `IPsec phase-2 negotiation failed: no proposal chosen` em todas as tentativas pós-renewal. A phase-1 estabelecia normalmente — o handshake IKEv2 completava e o túnel apresentava `Established` — mas qualquer pacote de produção que tentasse encapsulamento phase-2 era rejeitado.

O impacto operacional foi de aproximadamente 6 horas de roteirização manual emergencial para entregas last-mile Loggi do dia seguinte, com atraso médio de 90 minutos por rota afetada. Total estimado em valor de SLA não cumprido + remarcações: R$ 47.000 (TKT-20 referenced).

8.2 Topologia da VPN

Lado	Equipamento	IP público	Subnets protegidas
Apex	FortiGate 100F (CD Cajamar)	200...45	10.50.0.0/16
Loggi	Cisco ASA 5516-X		172.18.4.0/22

Phase-1 negociada (IKEv2): - Encryption: AES-256-GCM - Integrity: SHA-384 - DH group: 19 (ECP-256) - Lifetime: 28800s

Phase-2 negociada (ESP): - Encryption: AES-256-GCM - Integrity: SHA-256 - DH group: 19 (PFS habilitado) - Lifetime: 3600s

8.3 Procedimento Tier 2 (Marina) — diagnóstico

1. **Coletar logs do FortiGate filtrando pelo peer Loggi:**

```
 diagnose vpn ike log filter dst-addr4 <loggi-public>
diagnose debug enable
diagnose vpn ike log-filter src-addr4 200.<x>.<y>.45
```

2. **Trigger phase-2 manual:**

```
 diagnose vpn tunnel up <vpn-tunnel-name>
```

3. **Capturar 30 segundos de log + desabilitar debug:**

```
diagnose debug disable
```

4. **Procurar no log a linha de proposal mismatch.** Achado típico:

```
 responder: parsed SA_INIT response
responder: incoming proposal: ESP|AES-CBC-256|SHA1|DH14|PFS=Y
responder: configured proposal: ESP|AES-256-GCM|SHA256|DH19|PFS=Y
responder: no proposal chosen
```

5. **Diagnóstico confirmado.** A Loggi enviou SA proposal com **SHA1 + AES-CBC + DH14** após o renewal, divergindo claramente da config Apex (SHA256/GCM/DH19). A causa precisa ser identificada antes da remediation.

8.4 Causa-raiz e remediation TKT-20

A Loggi havia renovado o cert na ASA, mas o template aplicado pelo time de Loggi referenciava o `crypto map LEGACY` em uso desde 2019 (algoritmos SHA1/AES-CBC/DH14) ao invés do `MAP-2025-NEW` já presente na ASA mas não selecionado. A renovação havia sido feita por um plantonista que não conhecia a transição arquitetural em curso.

Apex não cedeu para SHA1 — o compliance NIST SP 800-131A formalmente deprecou SHA1 desde 2014 e o programa de segurança Apex audita aderência semestralmente. Marina, em coordenação com Fortinet TAC + ponto-focal Loggi, conduziu a remediation:

1. Loggi aplicou o `crypto map MAP-2025-NEW` em janela combinada (T+4h após detecção).
2. Apex re-triggou o túnel: `diagnose vpn tunnel up apex-loggi-prod`.
3. Phase-2 estabeleceu em ~3 minutos.
4. Tráfego de produção retomou ~T+4h15.

8.5 Lições aprendidas (capturadas no postmortem)

O postmortem do TKT-20 (publicado em 04/05/2026, Sev2) gerou três action items estruturais:

- Toda renovação de cert de VPN agora requer **validação dupla** — lado Apex confirma config do lado parceiro 24h antes da renewal, com checklist de algoritmos esperados.
- Adicionar **monitor SNMP** no FortiGate para alertar quando phase-2 não estabelece em <60s pós phase-1 sucesso (oid customizado configurado no FortiCloud).
- Manter documento `vpn-parceiros-config.xlsx` no SharePoint Tier 2 com algoritmos atuais de cada parceiro + data próxima renewal + ponto-focal técnico do parceiro.

8.6 Algoritmos aceitos pela política Apex (Q2-2026)

Categoria	Aceitos	Bloqueados
Encryption	AES-256-GCM, AES-256-CBC	AES-128-* (legado), 3DES, DES
Integrity	SHA-256, SHA-384, SHA-512	SHA-1, MD5
DH groups	19 (ECP-256), 20 (ECP-384), 21 (ECP-521), 14 (MODP-2048 mínimo legacy)	1, 2, 5 (MODP-768/1024/1536)
PFS	Obrigatório	Disabled (negar)

8.7 Inventário de túneis VPN ativos com parceiros

A Apex mantém o inventário abaixo de túneis VPN site-to-site com parceiros externos (excluídos os ~340 túneis de loja agregados no Virtual WAN). A revisão é mensal por Marina, com signoff trimestral por Bruno.

Parceiro	Tipo de tráfego	Última renewal cert	Próxima renewal	Algoritmos
Loggi	Last-mile orders + tracking callback	03/05/2026	03/05/2028	AES-256-GCM / SHA-384 / DH19
TOTVS auxiliar	Backup channel ERP (ExpressRoute alt)	12/01/2026	12/01/2028	AES-256-GCM / SHA-384 / DH19
Senior (provedor folha)	eSocial event submission	27/03/2026	27/03/2027	AES-256-GCM / SHA-256 / DH19
Manhattan Associates (WMS vendor)	Remote support tunnel	14/02/2026	14/02/2027	AES-256-GCM / SHA-256 / DH19
Banco Bradesco (folha + cobranças)	Transferências B2B em lote	09/04/2026	09/04/2027	AES-256-GCM / SHA-384 / DH20

A entrada Bradesco usa DH20 (ECP-384) ao invés de DH19 (ECP-256) por exigência de compliance do banco — a Apex não pôde optar por padrão único, mas a tolerância de algoritmos aceitos cobre ambos sem perda de segurança.

Página 9 — Renovação de certificado X.509

9.1 CA interna Apex

A infraestrutura de certificação Apex foi reestruturada em Q2-2025 após auditoria identificar incompatibilidade da CA legada (RSA-2048, SHA-1, validade 10 anos) com requisitos modernos. A nova hierarquia:

Root CA: `Apex Root CA 2024` — offline, HSM físico (cofre Bruno, com controle dual de acesso CTO + CFO). Validade 20 anos. Usada apenas para assinar a Issuing CA online. Cerimônia de uso requer 3 pessoas presentes + log físico assinado.

Issuing CA online: `Apex Issuing CA 01` — hospedada em Azure Key Vault Premium + dedicated HSM pool (FIPS 140-2 Level 3). Validade 10 anos. Operação dia-a-dia roda contra esta CA, isolada da Root.

Cadeia de confiança: distribuída via GPO (para devices joined no AD on-prem da sede), autoenrollment Intune (lojas + devices corp mobile), manual em devices não-domain (impressoras, IoT, Cisco IOS-XE).

9.2 Templates de certificado por uso

Template	Algoritmo	Validade	Renovação automática?
`WebServer-TLS`	RSA-3072 + SHA-256	1 ano	Sim (ACME interno)
`VPN-IKE-Cert`	ECDSA P-384 + SHA-384	2 anos	Não (manual + janela coordenada)
`Client-Auth-User`	RSA-2048 + SHA-256	6 meses	Sim (autoenrollment Intune)
`Device-Auth-Switch`	ECDSA P-256 + SHA-256	1 ano	Sim (SCEP via NDES)

A escolha de ECDSA P-384 para VPN-IKE é deliberada — algoritmos curve-based têm pegada de memória menor que RSA-3072 com força criptográfica equivalente (~192 bits de segurança), reduzindo o overhead do IKE em equipamentos com CPU constrained (FortiGate 100F lida com até 340 túneis simultâneos no Virtual WAN hub).

9.3 Procedimento de renovação VPN (manual coordenado)

1. **D-30:** alerta automático do Key Vault dispara para `lifecycle-vault@apex.com.br` (Marina + Bruno na lista).

2. **D-14:** Marina abre ticket de janela com a contraparte do parceiro VPN (e-mail formal + ticket via portal do parceiro quando aplicável).
3. **D-7:** janela confirmada. Documento de algoritmos validado em conjunto (vide 8.6) — todas as partes confirmam por escrito quais algoritmos vão ser usados pós-renewal.
4. **D-1:** dry-run em ambiente lab (FortiGate spare + ASA spare quando o parceiro fornece) para testar a nova cadeia. Esse passo não existia antes do TKT-20 — foi adicionado como action item do postmortem.
5. **D-day janela:**
   - Lado Apex gera CSR ECDSA P-384 no Key Vault: `az keyvault certificate create --vault-name apex-pki-vault --name vpn-loggi-prod-cert --policy @vpn-cert-policy.json`
   - Issuing CA emite cert com SANs corretos (FQDN do túnel `vpn-cajamar-public.apex.com.br` + IP público estático)
   - Cert importado no FortiGate: `config vpn certificate local · edit vpn-loggi-2026 · set source factory · set certificate "vpn-loggi-prod-cert"`
   - Lado parceiro recebe cert público + valida cadeia
   - Túnel reestabelecido + smoke test
6. **D+1:** validação ponta-a-ponta de tráfego real (não apenas ICMP) + sign-off Marina.
7. **D+7:** post-validation. Coletar SNMP da semana e validar que `phase-2-rekey` ocorre em <60s a cada lifetime expiration.

9.4 Sintomas de cert problemático

Sintoma	Diagnóstico
`peer's certificate is invalid (verify-ca)`	Cadeia do peer não chega no root configurado → revisar bundle
`peer's certificate has expired`	Renewal não foi feito · ativar plano emergencial
`peer's certificate signature does not match`	Algoritmo de assinatura divergente (SHA1 vs SHA256) → checar template
`peer's certificate CN does not match peer ID`	Subject Alt Name inconsistente → recriar com SAN do hostname público

9.5 Algoritmos depreciados (NÃO usar)

A lista de bloqueios duros, validada pelo programa de segurança e auditada semestralmente:

- **SHA-1** em qualquer contexto (NIST SP 800-131A formal deprecation desde 2014).
- **DH group 2** (MODP-1024) — quebrado pelo Logjam attack (2015).

- **RSA-1024** — equivalente a ~80 bits de segurança (NIST exige ≥112 bits).
- **3DES** — meet-in-the-middle attack reduz força efetiva para 112 bits.

Página 10 — ExpressRoute Azure (peering, BGP, MD5 auth)

10.1 Topologia ExpressRoute

Circuit	Capacidade	Provider	Local	SKU
SP primário	1 Gbps	Embratel	Equinix SP4	Premium
Cajamar primário	1 Gbps	Embratel	Equinix SP4	Premium
Recife DR	200 Mbps	Algar	Equinix RJ2	Standard

Os três circuits têm peering tipo **Microsoft + Private** habilitados. O peering Microsoft (rota Microsoft public services) é usado para Microsoft 365, Azure Storage public endpoints e Azure PaaS quando direct routing é preferível. O peering Private (rotas para VNets) carrega todo o tráfego para landing zone Apex.

Redundância: cada circuit tem duas conexões físicas (primary + secondary) na infraestrutura do provider, com VLAN tag dedicada para cada peering. Em caso de falha de uma conexão física, o tráfego converge automaticamente para a outra em <30 segundos (BFD habilitado no peering).

10.2 BGP — ASN allocation

ASN	Lado	Uso
12076	Microsoft	Edge Microsoft Brazil South
65010	Apex	Sede SP
65011	Apex	CD Cajamar
65012	Apex	CD Regional Recife (DR)
65020	Apex	TOTVS peering (cross-cloud)

Os ASNs 65010-65020 vêm do espaço **private ASN 16-bit** (64512-65534) reservado pela RFC 6996. A Apex não anuncia esses ASNs publicamente — todos os peerings com terceiros que requerem ASN público são feitos com encapsulamento BGP confederation ou através do peering Microsoft (que reescreve o AS_PATH para a saída internet).

10.3 BGP MD5 authentication

A autenticação MD5 é obrigatória em todos os peerings ExpressRoute. A senha MD5 é rotacionada anualmente em janela coordenada com a Microsoft via ticket CRR (Change Review Request) Premier Support.

Comando para verificar autenticação MD5 no edge router Apex (Cisco IOS-XE):

```
show ip bgp neighbors 192.168.255.1 | include MD5
```

Saída esperada:

```
TCP MD5 authentication is enabled.
```

A rotação de senha MD5 segue procedimento dual-key — chave atual + chave nova convivem por janela de 24h, durante a qual ambos os lados podem aceitar qualquer das duas. Após validação, a chave antiga é removida.

10.4 Troubleshooting BGP comum

Estado	Significado	Próxima ação
`Idle`	Peer não responde / config errada	Validar IP, ASN, MD5 dos dois lados
`Connect`	TCP 179 ainda não estabelecido	Checar firewall MD5 / routing intermediário
`Active`	Tentando handshake mas falhando	Provavelmente MD5 mismatch ou ASN errado
`OpenSent`	Negociando parâmetros	Verificar hold time + AS-path checks
`Established`	Peer up	Validar advertised + received prefixes

10.5 Procedimento Tier 2 (Marina) — peering caído

1. SSH no edge router: `ssh netadmin@<edge-router>`.
2. `show bgp summary` — identificar peer afetado (state ≠ Established).
3. `show ip bgp neighbors <peer-ip>` — capturar estado detalhado.
4. Validar reachability L3: `ping <peer-ip> source <local-loopback>`.

5. Se reachability OK: rodar `debug ip bgp <peer-ip>` por 30s (atenção: caro em CPU, parar imediatamente após coleta).
6. Analisar log — procurar mensagens `Notification: bad MD5 digest` ou `Open Hold Timer expired`.
7. Confirmar MD5 com Microsoft via Premier Support (Severity B se circuit primário down).
8. Se MD5 OK: validar prefix-list e route-map (advertised count batendo expected).

10.6 Métricas SLA observadas (últimos 6 meses)

Circuit	Uptime real	Downtime (h)	Mean ms RTT (Apex→Azure)
SP Primário	99.997%	1.3h	4.2 ms
Cajamar Primário	99.995%	2.2h	5.1 ms
Recife DR	99.92%	8.7h	18.3 ms

O downtime do Cajamar Primário inclui o evento de 14/02/2026 (TKT-20-relacionado pela proximidade temporal — Marina diagnosticou interferência cruzada no edge MSEE Equinix que afetou tanto VPN parceiros quanto ExpressRoute por 90 minutos). O downtime de Recife DR concentra-se em dois eventos de manutenção planejada do provider Algar (8h cada) e foi considerado dentro do SLA contratado.

10.7 Test routine — failover de ExpressRoute

A Apex executa drill trimestral de failover de ExpressRoute para validar que o caminho secundário absorve carga sem regressão de SLO. O procedimento, conduzido em janela noturna acordada com Microsoft Premier Support (sev C ticket pre-opened), segue cinco passos:

1. **T-7 dias:** Marina abre ticket Premier Support comunicando data + hora + circuit alvo. Microsoft confirma readiness do lado deles.
2. **T-1 dia:** dry-run de comandos em ambiente lab espelhado (`expressroute-drill-lab.bicep`). Validação de routing convergence em <60s.
3. **T-hora-zero:** Marina degrada link primário via comando administrativo no edge router: `shutdown` na interface dedicada ao primary peering.
4. **T+1 min:** validar convergência via `show bgp summary` no edge — peer primário cai, peer secundário absorve advertências. RTT pode subir temporariamente (esperado: +2-4ms enquanto roteamento estabiliza).
5. **T+30 min:** validar throughput agregado mantém-se em 80%+ da capacidade nominal. Health endpoints internos confirmam que workloads não observaram impacto material.
6. **T+60 min:** reabrir interface primária: `no shutdown`. Validar convergência reverse.

Resultados dos últimos 4 drills:

Drill	Convergence time	RTT delta	SLO regression
Q3-2025	38s	+3.1ms	0% (todos endpoints dentro)
Q4-2025	42s	+2.8ms	0.02% (1 endpoint timeout transitório)
Q1-2026	35s	+2.4ms	0%
Q2-2026	31s	+2.2ms	0%

A tendência de melhoria reflete tuning do BFD timer + hold time do BGP no edge.

Página 11 — Frota.io webhook (TKT-15 âncora)

11.1 Cenário

Desde 17h00 de ontem (BRT) o Frota.io parou de receber pedidos novos do TMS interno. O webhook REST do TMS reportava `200 OK` em todas as chamadas para `POST https://api.frota.io/v1/orders`, mas os pedidos não apareciam na fila de roteirização do Frota.io. O CD Cajamar precisou rodar roteirização manual emergencial para as entregas D+1, com impacto operacional de R$ 38.000 (atrasos last-mile + remarcações + esforço extra de equipe noturna).

11.2 Topologia da integração

```
TMS Apex (Azure App Service) —[OAuth2 client credentials]—→ Frota.io (api.frota.io)
                                                                  │
                                                                  └—→ Frota.io Worker queue
```

Authentication: OAuth2 client_credentials grant com Service Principal `sp-frota-tms-prod` (registrado no Entra ID tenant Apex). **Endpoint token:** `https://auth.frota.io/oauth/token` **Scope:** `orders:write routes:read` **Token TTL:** 3600s (renovação automática iniciada 5 minutos antes da expiração)

11.3 Diagnóstico Tier 2 (Marina)

1. **Validar logs do App Service via Log Analytics:**

```
AppServiceConsoleLogs
| where TimeGenerated > ago(24h)
| where ResultDescription contains "frota.io"
| order by TimeGenerated desc
```

Achado: requisições retornavam **HTTP 401 Unauthorized** intermitentes desde 17h13 de ontem.

2. **Validar Service Principal no Entra ID** — `sp-frota-tms-prod`. Inspecionar last credential rotation date.
3. **Causa-raiz identificada.** O secret do SP foi rotacionado às 17h00 da rotina mensal automática Apex IT (CSV de SPs flagged para rotation gerou job ARM template execution). A aplicação TMS lia o secret do Key Vault via reference em App Service config (`@Microsoft.KeyVault(SecretUri=...)`), mas o cache local do App Service mantinha o valor antigo por TTL de 12 horas (default da plataforma).
4. **Confirmação cruzada.** O Frota.io reportava 200 OK no `POST /orders` porque o token de fato chegava (assinatura JWT válida + claim presente), mas a tentativa de validação do scope no Frota.io retornava 401 silencioso. Bug do lado Frota.io: deveriam retornar 401 explícito ao chamador do webhook quando token rejeitado.

11.4 Remediation imediata

1. **Restart do App Service** para invalidar cache de secret:

```
az webapp restart --name app-tms-prod --resource-group rg-tms-prod
```

2. Validar primeiro pedido em <2 minutos pós-restart (smoke test automatizado roda a cada minuto).
3. Coletar tokens consumidos no Entra ID Audit Log:

```
AADServicePrincipalSignInLogs
| where ServicePrincipalName == "sp-frota-tms-prod"
| where TimeGenerated > ago(2h)
```

11.5 Remediation estrutural

A solução de longo prazo foi entregue em sprint Q2-2026:

1. **Migração SP → Managed Identity.** A `app-tms-prod` agora usa System-Assigned Managed Identity para autenticar contra o Frota.io. O Frota.io aceita Federated Credentials via OIDC trust com o tenant Apex Entra ID. Isso elimina a rotação de secret e o cache de valor antigo no App Service.
2. **Healthcheck endpoint** que valida o token a cada 5 minutos e emite métrica `auth_token_age_seconds` para Azure Monitor.
3. **Alert** via Azure Monitor quando `auth_token_age_seconds > 3300` (faltam menos de 5 minutos para a expiração) — escalation Tier 2 imediata.

4. **Coordenação com Frota.io** para reportarem 401 explícito no webhook callback (issue acompanhado pela equipe Vendor Management).

11.6 Padrão de retry recomendado

Para todas as integrações OAuth2 client_credentials do TMS:

- **Backoff exponencial** com jitter (start 1s, max 30s).
- **3 retries** automáticos em 401/403/500/502/503/504.
- **Circuit breaker** após 5 falhas consecutivas — pausa 60s antes de re-tentar.
- Logs estruturados com `correlation-id` propagado end-to-end (Application Insights captura via `Operation_ParentId`).

11.7 Outras integrações similares — inventário Apex

A migração de Service Principal para Managed Identity está em rolling-update através do portfolio Apex. O status atual:

Workload	Auth atual	Target	Status migration
`app-tms-prod` ↔ Frota.io	Managed Identity (OIDC federation)	Managed Identity	Done (Q2-2026)
`app-tms-prod` ↔ Loggi (REST callbacks)	Managed Identity	Managed Identity	Done (Q1-2026)
`app-ecommerce-prod` ↔ Cielo gateway	mTLS cert	mTLS cert	N/A (mantém cert pinning PCI)
`app-erp-bridge` ↔ TOTVS	Service Principal (secret)	Managed Identity	InProgress (Q3-2026 target)
`app-rh-folha` ↔ Senior eSocial	Service Principal (cert)	Managed Identity	Planned (Q4-2026)
`app-notifications` ↔ Microsoft Graph	Managed Identity	Managed Identity	Done (Q1-2026 pós TKT-17)

A modalidade Managed Identity em conjunto com Workload Identity Federation cobre 85% dos casos. Os 15% remanescentes são workloads on-prem ou em outras clouds (TOTVS) que não suportam o protocolo OIDC federation ainda — para esses, mantém-se Service Principal com cert ao invés de secret (cert tem rotação mais robusta e auditável).

CAPÍTULO 4 — Identidade e SSO

Página 12 — Entra ID (Azure AD) + sync AD on-prem

12.1 Topologia identity

A identidade na Apex é estruturada em modelo híbrido com **master no AD on-prem** para colaboradores e **cloud-only** para Service Principals e Workload Identities.

Componente	Descrição
Tenant Entra ID	`apex.onmicrosoft.com`
Domínios federados	apex.com.br, apexmercado.com.br, apextech.com.br, apexmoda.com.br, apexcasa.com.br, apexlogistica.com.br + 6 marcas restantes
AD on-prem forest	`corp.apex.local` · 4 DCs (2 sede SP + 2 CD Cajamar)
Sync engine	Azure AD Connect cloud sync (substituiu Connect Sync v1 em Q3-2025)
Sync interval	2 minutos (near real-time)
Identity master	AD on-prem (source of authority para colaboradores)
Cloud-only	Service Principals + Workload Identities

12.2 Authentication flow padrão (colaborador)

O fluxo abaixo é o SSO típico de colaborador acessando aplicação corporativa:

1. Colaborador acessa `https://portal.apex.com.br/sso`.
2. Redirect para `login.microsoftonline.com/<tenant-id>`.
3. Entra ID identifica domínio federado → redireciona para AD FS on-prem.
4. AD FS valida credencial (Kerberos contra DC) → emite SAML token.
5. Browser submete SAML token de volta para Entra ID.
6. Entra ID emite OIDC ID token + access token → app recebe e cria sessão.

12.3 MFA — obrigatório para 100% dos colaboradores desde Q1-2026

- **Método primário:** Microsoft Authenticator push, com **number matching** habilitado contra MFA fatigue (push spam exigindo aprovação manual digitando número curto que aparece na tela do app).
- **Método secundário:** OATH TOTP hardware (Yubikey 5C-NFC para roles privilegiados — admins AD, admins Azure, roles PIM).
- **Fallback:** SMS apenas para break-glass account. Proibido para uso geral (SIM-swap risk).

12.4 Conditional Access policies em vigor (Q2-2026)

Policy	Condição	Ação
`CA01-MFA-All`	Todos os usuários, todas as apps	Require MFA
`CA02-Block-Legacy-Auth`	Legacy auth protocols (IMAP, POP, SMTP basic)	Block
`CA03-Block-NoBrazil`	Login outside BR + não-marcado como travel	Block (escalation Bruno)
`CA04-Compliant-Device`	Apps M365 + ERP	Require Intune compliance
`CA05-PIM-Privileged`	Roles privilegiados (Global Admin, etc)	Require PIM activation + approval

12.5 Falhas comuns no sync AD↔Entra ID

Sintoma	Causa	Remediation
Novo usuário criado no AD não aparece no Entra ID após 2h	Filtro OU sync excluiu	Validar `Get-ADSyncRule` filtros
Atributo desatualizado (telefone, cargo)	Conflito por null vs valor	Verificar `MS-DS-ConsistencyGuid`
Usuário desabilitado AD continua logando no Azure	Account expired flag não sincronizou	Forçar `Start-ADSyncSyncCycle -PolicyType Delta`
Senha não sincroniza	PHS Agent falhou	Reiniciar serviço `Microsoft Azure AD Connect Cloud Sync` no servidor agent

12.6 Decisão arquitetural — sync engine

A migração de Azure AD Connect Sync v1 (servidor dedicado on-prem) para Azure AD Connect cloud sync (agente leve) ocorreu em Q3-2025. As razões:

1. **Eliminação de single point of failure on-prem.** O servidor dedicado do AAD Connect Sync v1 representava risco operacional — qualquer falha do servidor (patch que quebrava, disco cheio de logs, falha de hardware) parava o sync de 8.000 contas. O cloud sync agent é leve e roda em múltiplas máquinas DC (HA nativo).
2. **Redução de footprint.** Antes: VM Windows Server 2019 dedicada + SQL Server LocalDB para metaverso. Depois: agente roda no próprio DC (Windows Server 2022) sem requisitos adicionais de banco.
3. **Patching simplificado.** Cloud sync recebe updates automatically gerenciados pela Microsoft sem janela de manutenção customizada Apex.
4. **Modelo de configuração unificado.** Filter rules são gerenciadas no portal Entra ID, não em GUI legacy on-prem com terminologia técnica diferente.

A migração foi planejada em 4 fases por 6 semanas, com janela de coexistência onde os dois engines rodavam paralelo (ler-only no cloud sync inicialmente, depois write-mode). Zero incidente reportado durante a migração.

Página 13 — TKT-17 âncora (12 funcionários sem reset SSO)

13.1 Cenário (resolvido em Q1-2026)

A política mensal de password rotation do Entra ID notifica colaboradores 7 dias antes do vencimento da senha. Em janeiro/2026, 12 colaboradores da matriz SP não receberam o e-mail de aviso. Quando a senha expirou, ficaram bloqueados na manhã seguinte (08h-09h) e abriram 12 tickets P1 paralelos no HelpSphere. Diego identificou padrão (12 tickets idênticos em janela de 1h) e escalou para Marina, que escalou para Bruno dado o impacto em produtividade + risco regulatório (interrupção de SLA atendimento).

13.2 Investigação

1. **Coletar Audit Log do Entra ID:**

   ```
   AADAuditLogs
   | where TimeGenerated > ago(7d)
   | where OperationName == "Send password expiration notification"
   | where TargetResources has_any (lista-12-usuarios)
   ```

   Resultado: nenhuma tentativa de envio registrada para os 12 usuários afetados.

2. **Investigar o app que envia notificações.** PowerShell script rodando em Azure Automation runbook, autenticado via Service Principal `sp-password-notify-prod`.
3. **Audit Log do SP:**

```
AADServicePrincipalSignInLogs
| where ServicePrincipalName == "sp-password-notify-prod"
| where ResultDescription contains "rate"
```

4. **Causa-raiz.** O SP atingiu rate-limit do Graph API (scope `Mail.Send`) após renewal de credenciais — a rotação de credentials disparou em massa requests retried pelo orquestrador do runbook. Apenas 188 dos 200 alvos receberam notificação. Os 12 azarados foram exatamente os últimos da fila quando o rate-limit cortou a execução.

13.3 Remediation imediata

1. Reset manual de senha dos 12 colaboradores pela equipe Identity (Bruno autorizou exceção PIM emergencial).
2. Senha temporária comunicada via canal seguro (gerente direto entregou pessoalmente em ambiente controlado).
3. `Force password change at next logon = true` aplicado em todas as 12 contas.
4. Validação: todos os 12 logaram normalmente em até 4 horas.

13.4 Remediation estrutural (entregue em sprint Q1-2026)

- **Migração SP → Managed Identity** para Automation account. A System-Assigned Managed Identity do runbook recebeu role `Microsoft Graph Mail.Send` via Application Permissions, eliminando o roll-over de secret.
- **Throttle interno no script** — máximo 50 envios por minuto (abaixo do rate-limit Graph documentado em 60/min). Implementado via `Start-Sleep` calibrado.
- **Healthcheck do envio** — script reporta métricas `notifications_sent_total` e `notifications_failed_total` para Azure Monitor via REST endpoint customizado.
- **Alert** se `notifications_failed_total > 0` na execução mensal — paging direto para Marina.

13.5 Service Principal vs Managed Identity — quando usar cada um

Cenário	Recomendação
Workload rodando em Azure (App Service, Function, AKS, VM, Automation)	**Managed Identity** sempre
Workload rodando on-prem ou em outra cloud	Service Principal (com cert ao invés de secret se possível)
Integração third-party que precisa de credenciais visíveis	Service Principal com secret rotacionado
Pipeline CI/CD GitHub Actions	OIDC federation → Managed Identity equivalente

A política Apex desde Q1-2026 é clara: **toda nova workload em Azure deve usar Managed Identity por default.** Exceções precisam de aprovação Bruno + justificativa documentada (caso típico: app legacy que não suporta MSAL ou Workload Identity SDK).

Página 14 — Password rotation policy + break-glass

14.1 Política Apex (Q2-2026)

Categoria de conta	Validade	MFA?	Reset self-service?
Colaborador padrão	90 dias	Sim	Sim (SSPR)
Privilegiado (admin AD, admin Azure)	60 dias	Sim + PIM	Sim (com aprovação)
Service account on-prem (legado)	365 dias	Não aplica	Não (manual via Identity team)
Service Principal Entra ID	365 dias (cert) ou 180 dias (secret)	N/A	N/A (automation rotation)
Break-glass	**NUNCA expira**	**Sim** (FIDO2 hardware)	**NUNCA** (manual emergencial)

14.2 Break-glass accounts

Princípio: acessos de último recurso quando todo o tenant Entra ID estiver inoperante. Cenário hipotético: tenant Apex sofre lockout durante incidente de configuração de Conditional Access (e.g., admin aplicou CA policy que bloqueia o próprio admin).

Apex mantém **dois break-glass accounts**: - `breakglass-01@apex.onmicrosoft.com` - `breakglass-02@apex.onmicrosoft.com`

Características obrigatórias, alinhadas com o guia formal Microsoft de break-glass:

1. **Cloud-only** (não sincronizadas com AD on-prem).
2. **Excluídas de TODAS as Conditional Access policies** (especialmente Block-NoBrazil e Compliant-Device).
3. **MFA via FIDO2 hardware key apenas** — Yubikey 5C-NFC custodiada fisicamente em cofre (Bruno + Carla mantêm acesso dual).
4. **Senha gerada com 64+ caracteres** — armazenada em envelope lacrado em cofre. Bruno + Carla mantêm metade cada (split-knowledge).
5. **Monitoramento 24/7** — alerta Sentinel para QUALQUER uso (login bem-sucedido ou falho).
6. **Auditoria mensal** — validação que MFA hardware funciona + cofre intacto + Conditional Access continua excluindo as contas.

14.3 Procedimento de uso de break-glass (emergencial)

1. Bruno (CTO) declara incidente Sev1 + autoriza uso explicitamente (registro escrito em canal `#incident-bridge`).
2. Carla entrega meia senha + Bruno entrega meia senha (controle dual).
3. Login em workstation isolada (não corporativa, normalmente notebook offline mantido para o propósito) com FIDO2 Yubikey.
4. Toda ação registrada em log físico + sessão gravada (OBS Studio configurado no notebook).
5. Após resolução: reset imediato da senha + nova FIDO2 emitida + sessão arquivada.
6. Postmortem mandatório dentro de 5 dias úteis, revisado em comitê com CISO virtual (consultoria externa Apex contratada).

14.4 Self-Service Password Reset (SSPR)

- Habilitado para 100% dos colaboradores desde Q4-2024.
- 2 métodos de verificação obrigatórios (de 4 possíveis: Authenticator, OATH TOTP, e-mail pessoal validado, SMS).
- SMS desabilitado para roles privilegiados (apenas hardware key permitida).
- Logs SSPR retidos por 365 dias no Sentinel para forensics.

A adoção do SSPR reduziu os tickets de “senha esquecida” no HelpSphere em ~78% entre Q4-2024 e Q1-2025 (de ~340/mês para ~75/mês). Os 75 residuais são compostos majoritariamente por colaboradores que não completaram registro dos métodos de verificação ou perderam o número de telefone cadastrado.

14.5 PIM — Privileged Identity Management

A Apex usa Entra ID PIM para gerenciar elevation de roles privilegiados. O modelo é **just-in-time**: nenhum colaborador é Global Admin ou Owner permanente — todos os acessos privilegiados são solicitados sob demanda, aprovados, ativados por janela limitada e auditados.

Role	Eligible (lista permanente)	Active (just-in-time)	Janela default
Global Administrator	3 (Bruno + 2 backups)	0 permanente	4h (com aprovação CTO)
Application Administrator	12 (Tier 2 + Tier 3)	0 permanente	2h
Conditional Access Administrator	6 (Identity team + Bruno)	0 permanente	2h
Authentication Administrator	4 (Identity team)	0 permanente	1h
Reports Reader	24 (broad permission)	24 permanente	N/A (read-only)

A configuração de elevation requer: 1. Justificativa textual (mínimo 30 caracteres) obrigatória ao solicitar. 2. Aprovação por outro Eligible (controle dual) para Global Admin. 3. MFA via FIDO2 hardware key durante a ativação. 4. Sessão gravada via Azure Activity Log + Sentinel automation rule paginando para Marina + Bruno.

Histórico de elevations Q2-2026 (até a data desta versão): - Global Administrator: 4 ativações (todas justificadas + aprovadas). - Application Administrator: 28 ativações (rotina de gerenciamento de Conditional Access). - Conditional Access Administrator: 11 ativações. - Authentication Administrator: 6 ativações (relacionadas a SSPR troubleshooting).

CAPÍTULO 5 — Capacity e performance

Página 15 — Postmortem Black Friday 2025 (TKT-18 âncora)

15.1 Sumário executivo

Incidente: o site `apexmoda.com.br` (Apex Moda) ficou indisponível durante 47 minutos no pico da Black Friday 2025 (28/11/2025), entre 23h13 e 00h00. Aproximadamente 3.200 sessões de checkout foram afetadas — tanto checkouts em andamento (carrinho cheio) quanto novas visitas que não

conseguiam carregar a página inicial. **GMV perdido estimado em R$ 1.870.000**, calculado com base no conversion rate médio das 4 horas anteriores (4.8%) e no ticket médio do segmento Apex Moda no evento (R$ 580).

15.2 Timeline detalhada (28/11/2025)

Hora BRT	Evento	Detector
19h00	Black Friday inicia · tráfego baseline pré-evento ~800 RPS	—
22h45	Tráfego escala a ~3.500 RPS (4.4x baseline)	Application Insights
23h00	Auto-scale do App Service (B3 Premium) começa a adicionar instâncias	Activity Log
23h08	App Service atinge **10 instâncias** (teto configurado da SKU)	Activity Log
23h09	Latência P95 sobe de 280ms para 1200ms	App Insights alert
23h11	Tráfego cresce para ~5.800 RPS (carga ~17 instâncias)	App Insights
23h13	Primeiras 5xx começam · taxa erro 8%	Front Door analytics
23h15	NOC recebe alerta P1 · Diego escala Marina	HelpSphere
23h22	Bruno acionado (Sev1 declarado)	Slack incident-bridge
23h27	Diagnóstico: SKU B3 não suporta scale-out adicional · decisão de pivot	War room
23h31	Scale-up para Premium v3 P2v3 iniciado (60 instâncias capacity)	Az CLI manual
23h44	Premium v3 P2v3 ativo + 18 instâncias warm	Activity Log
23h52	Erros 5xx caem para <0.5%	App Insights
00h00	Operação normal restabelecida · sign-off Bruno	Slack

15.3 Análise de causa-raiz (5-whys)

1. **Por que o site caiu?** App Service não conseguiu absorver o pico de tráfego.
2. **Por que não conseguiu?** Plano B3 Premium configurado com max 10 instâncias.
3. **Por que estava configurado para max 10?** Configuração padrão do template Bicep do landing zone — nunca foi reavaliada após a Black Friday 2024.
4. **Por que não foi reavaliada?** Não havia processo formal de capacity review trimestral pré-eventos comerciais.
5. **Por que não havia processo?** Programa de capacity planning não havia sido formalizado. Responsabilidade implícita do DevOps sem RACI claro.

A causa-raiz declarada formalmente no postmortem foi **ausência de programa formal de capacity planning trimestral**. Os action items consequentes atacaram essa lacuna sistemicamente — não apenas reconfiguraram a Apex Moda, mas estabeleceram o processo permanente.

15.4 Impacto financeiro detalhado

Item	Valor estimado
GMV perdido durante 47 min de indisponibilidade	R$ 1.870.000
Custo de aceleração de scale-up (Premium v3 instances 24h post-incident)	R$ 14.300
Esforço de engenharia (war room 4h + postmortem 12h)	R$ 28.000 (custo interno fully-loaded)
Reputational damage (NPS Apex Moda caiu 4 pontos no mês)	Não mensurado financeiramente
Total quantificado	**R$ 1.912.300**

15.5 Action items + status (Q2-2026)

AI	Owner	SLA	Status
AI-1: Reconfig App Service Plan apexmoda para Premium v3 P2v3 max 30 + warm pool 5	Bruno	D+7	Done (06/12/2025)
AI-2: Capacity planning trimestral formalizado (Q-1 antes de eventos)	Bruno + Carla	Q1-2026	Done (programa lançado 15/01/2026)
AI-3: Load testing trimestral em sandbox idêntico à prod	DevOps	Q1-2026	Done (k6 + JMeter scripts versionados)
AI-4: Front Door + CDN aggressive caching para páginas estáticas + APIs read-mostly	DevOps	Q1-2026	Done (cache hit ratio subiu de 42% para 78%)
AI-5: Alert SLO-based (não infrastructure-based)	DevOps + SRE	Q2-2026	InProgress (50% das services migrated)
AI-6: Postmortem template padrão + repositório centralizado	Bruno	Q1-2026	Done (Confluence space `Postmortems`)

A taxa de cumprimento de action items dentro do SLA (6/6 Done ou InProgress dentro do prazo) é considerada exemplar pelo programa de qualidade interno e foi usada como referência em treinamento para outras lideranças.

15.6 Investimento em prevenção pós-postmortem

O postmortem da Black Friday 2025 deflagrou capex de prevenção de R$ 285.000 ao longo de Q1-Q2 2026, distribuído da seguinte forma:

Investimento | Capex (R$) | Justificativa |

|—|—|—| | Upgrade App Service Plan apexmoda B3 → P2v3 max 30 + warm pool 5 | 84.000/ano (opex incremental) | Capacity headroom para BF + DM | | Front Door Premium + WAF rules + cache aggressive | 38.000 setup + 22.000/ano | Reduce origin load + DDoS protection | | Tooling Load Testing (k6 Cloud subscription + scripts dev) | 24.000 setup | Drill trimestral em sandbox idêntico prod | | Treinamento SRE (4 colaboradores · capacity engineering + cost optimization) | 32.000 | Maturidade interna em SRE | | Consultoria Microsoft FastTrack (Cloud Adoption Framework review) | 64.000 | Validação externa do landing zone | | Sandbox Bicep template + automação de spin-up |

12.000 (esforço interno) | Reproducible load test env | | Refresh de instrumentation (Application Insights agent + custom metrics) | 14.000 | Visibilidade granular pre-pico | | Repositório `apex-loadtest` + CI/CD scripts | 8.000 (esforço interno) | Versionamento + peer review de testes | | **Total Capex visível** | **216.000** | (excluído opex incremental ano-cheio R$ 106k) |

O ROI estimado considera que a remediation deve evitar incidentes similares pelos próximos 3 anos com confiança alta (~80%). Comparado ao impacto de R$ 1.870.000 do incidente original, o investimento se paga em <2 meses de operação evitada.

Página 16 — Capacity planning + warm pool

16.1 Programa de capacity planning (lançado Q1-2026)

Cadência: trimestral, com revisão em **Q-1** (trimestre anterior) ao evento comercial alvo. Reuniões formais agendadas no calendário corporativo com presença obrigatória de Bruno (CTO), DevOps Lead, SRE Lead (em formação), Carla (CFO para approval de Capex extra), CMO/CCO (para projeção de tráfego marketing-driven).

Eventos comerciais críticos do calendário Apex:

- **Black Friday** (final novembro) — pico esperado 6-8x baseline.
- **Natal/Reveillon** (dezembro) — sustentação alta · pico 3-4x.
- **Dia das Mães** (maio) — pico 2.5x (especialmente Apex Moda + Apex Casa).
- **Black November** (mês completo) — sustentação 2-3x baseline durante novembro inteiro.

16.2 Inputs do capacity review

1. Histórico de RPS, P95 latency, error rate (12 meses).
2. Projeções de marketing (campanhas, descontos, tier de mídia paga).
3. Custo Azure mensal por workload + simulação cost-impact da nova capacity.
4. SLO targets por workload (e.g., apexmoda checkout: 99.95% mensal, P95 ≤500ms).

16.3 Outputs do capacity review

1. **Capacity plan** por workload — qual SKU + quantas instâncias min/max + warm pool size.
2. **Load test script** atualizado em k6 ou JMeter — simula carga projetada + 30% headroom.
3. **Runbook de scale-up emergencial** (caso mesmo o plano falhe) — comandos Az CLI prontos para execução em <5 minutos.
4. **Comunicação** para stakeholders (CFO orçamento + CMO/CCO calendário).

16.4 Warm pool — quando aplicar

Warm pool = instâncias provisionadas e quentes que recebem tráfego imediatamente, pulando cold start.

Workload	Warm pool size	Justificativa
`apexmoda-checkout` (App Service P2v3)	5 instâncias	Black Friday + Dia das Mães · cold start ~90s inaceitável
`apextech-catalog-api` (Function Premium)	3 instâncias	Variabilidade tráfego catalog browsing
`apexlogistica-tms` (App Service P1v3)	0 (sob demanda)	Tráfego B2B estável · cold start aceitável
`apex-internal-bff` (AKS)	2 pods replica permanente	Latency-sensitive interno

16.5 Load testing trimestral — workflow

1. **D-21:** Marina + DevOps definem cenários de teste (read-heavy, write-heavy, mixed).
2. **D-14:** scripts k6 versionados em `apex-loadtest` repo · revisão peer obrigatória antes do merge.
3. **D-7:** spin-up de sandbox idêntico à prod (Bicep `loadtest-sandbox.bicep` provisiona em ~30 min).
4. **D-1:** dry-run em 30% da carga alvo · validar instrumentation está coletando o esperado.
5. **D-day:** execução completa · 4h de duração com warm-up → ramp-up → sustained → ramp-down.
6. **D+1:** análise de resultados (Grafana dashboards) · identificar bottlenecks.
7. **D+7:** relatório executivo para Bruno + Carla · ajustes de capacity plan se necessário.

16.6 Métricas-chave monitoradas em produção

Métrica	Threshold warning	Threshold critical
CPU instance média	>65% sustentado 10min	>85% sustentado 5min
Memory instance média	>70% sustentado 10min	>90% sustentado 5min
HTTP 5xx rate	>0.5% por 5min	>2% por 2min
P95 latency (checkout endpoint)	>500ms por 5min	>1000ms por 2min
Healthcheck failures consecutivos	2	5
Queue depth (Service Bus)	>1000 mensagens	>5000 mensagens

Todos os thresholds são monitorados via Azure Monitor + alertas roteados para PagerDuty conforme severidade. Thresholds `warning` notificam canal Slack `#observability-warn`. Thresholds `critical` paginam Tier 2 imediatamente.

16.7 Calendário de capacity drills 2026

O programa formal de capacity testing roda quatro drills anuais alinhados com eventos comerciais críticos. Cada drill tem prep-window de 21 dias + 1 dia de execução + 7 dias de análise.

Drill	Foco principal	Prep start	Execução	Workload alvo
D1-2026 (Q1)	Dia dos Namorados (12/06)	02/05	23/05	apexmoda + apextech checkout
D2-2026 (Q2)	Dia dos Pais (10/08)	30/06	21/07	apexmoda + apexmercado e-comm
D3-2026 (Q3)	Black November pre-event	30/09	21/10	TODOS workloads B2C
D4-2026 (Q4)	Reveillon + Reis Magos	02/12	12/12	apextech + apexmercado pico fim de ano

A cadência trimestral permite identificar regressão de performance entre drills — se o workload `apexmoda-checkout` sustentou 6.000 RPS em D1 mas só 4.500 em D2 (com mesma SKU), há regressão a investigar antes do BF.

16.8 SLOs por workload — visão consolidada

A Apex adotou Service Level Objectives (SLOs) ao invés de SLAs internos como mecanismo de medição interna de qualidade. SLOs trabalham sobre janelas de 28 dias rolling, com error budget burndown como gatilho de freezing de mudanças.

Workload	Availability SLO	Latency SLO (P95)	Error Budget (28d)
apexmoda-checkout	99.95%	<500ms	20.16 min
apexmoda-catalog	99.9%	<300ms	40.32 min
apextech-checkout	99.95%	<500ms	20.16 min
apexmercado-ecomm	99.9%	<400ms	40.32 min
TMS-Frota.io webhook	99.5%	<2000ms	3h 21min
ERP-bridge	99.95%	<100ms	20.16 min
Bacen PIX gateway	99.99%	<300ms	4.03 min

Quando 50% do error budget é consumido em <14 dias, o workload entra em **slowdown mode** — release freeze + foco em reliability. Quando 100% é consumido, **release freeze total** até queima do budget retornar a normal.

CAPÍTULO 6 — Escalação e postmortem

Página 17 — Fluxo de escalação Tier 1 → Tier 3 → Vendor

17.1 Tiers de suporte

A estrutura de tiers permite que problemas simples sejam resolvidos com baixo custo (Tier 1 a R$ 45/hora fully-loaded) e que problemas complexos cheguem rapidamente a especialistas (Tier 2 a R$ 180/hora, Tier 3 a R$ 450/hora). A escalação errada — Tier 1 sentando em problema Tier 2 — é a maior fonte de overrun de SLA.

Tier	Quem	Responsabilidade	Ferramentas
Tier 0	Self-service (chatbot, KB pública)	Resoluções FAQ	HelpSphere bot
Tier 1	Diego (atendente)	Triagem + procedimentos padrão runbook	HelpSphere portal
Tier 2	Marina (Network Eng)	Troubleshooting profundo · acesso SSH/console	FortiCloud, Azure Portal, NetBox
Tier 3	Bruno (CTO)	Decisões estruturais · autoriza vendor escalation	Premier Support, vendor TAM
Vendor	Fortinet, Cisco, MS, Hikvision	Suporte L3 do produto · RMA	TAC respectivo

17.2 Critérios de escalação Tier 1 → Tier 2

Diego **DEVE** escalar para Marina quando:

1. Procedimento de runbook executado completamente sem resolver.
2. Múltiplas lojas afetadas simultaneamente (≥3).
3. Loja inteira down (qualquer SLA tier).
4. Suspeita de comprometimento de segurança (qualquer indicador IOC observado).
5. Solicitação requer acesso SSH/console (vedado Tier 1 por política de least-privilege).
6. Cliente VIP (>R$ 50k/ano de relacionamento ativo) reporta indisponibilidade.

17.3 Critérios de escalação Tier 2 → Tier 3

Marina **DEVE** escalar para Bruno quando:

1. Incidente classificado como Sev1 (impacto financeiro projetado >R$ 100k OU múltiplos sites Tier 0-2 afetados).
2. Decisão envolve mudança de arquitetura (e.g., reconfigurar peering ExpressRoute).
3. Solicitação requer aprovação financeira (>R$ 10k não-orçado).
4. Vendor escalation precisa de aval contratual (e.g., Premier Support hour burndown).
5. Comunicação externa necessária (mídia, regulador, parceiro estratégico).
6. Suspeita de comprometimento de segurança confirmada.

17.4 Critérios de vendor escalation

Bruno autoriza vendor escalation quando:

- Bug confirmado do produto após exaustar troubleshooting interno.
- RMA de hardware (DOA, falha em garantia).
- Premier Support ticket Severity A (Microsoft, Cisco) ou equivalente Fortinet TAC.
- Pedido de feature request com impacto de negócio mapeado.

17.5 SLAs internos de resposta

Severidade	Time-to-acknowledge	Time-to-resolve objetivo	Quem decide severidade
Sev1 (Critical)	<5 min	<2h	Bruno (CTO)
Sev2 (High)	<15 min	<8h	Marina (Tier 2)
Sev3 (Medium)	<1h	<24h	Marina (Tier 2)
Sev4 (Low)	<4h	<72h	Diego (Tier 1)

17.6 War room — quando convocar

Sev1 sempre triggers war room. Convocação imediata em canal Slack `#incident-bridge` + bridge Teams ativada por Marina ou Bruno.

Composição mínima do war room:

- 1 **Incident Commander** (IC) — Marina ou Bruno.
- 1 **Communications Lead** — Lia (Head Atendimento, comunica clientes/lojistas).
- 1 **Scribe** — registra timeline em real-time (apoio Diego ou backup).
- N Subject Matter Experts (variável por natureza — DBA, network, security, vendor TAM).

Frequência de comunicação durante incidente Sev1:

- Update interno (war room): a cada 15 minutos.
- Update stakeholders (Carla CFO, Bruno CTO): a cada 30 minutos.
- Update externo (lojistas, parceiros, mídia se aplicável): a cada 60 minutos.

17.7 Métricas de qualidade da escalação

A qualidade do processo de escalação é monitorada em três KPIs principais:

KPI	Q1-2026	Q2-2026	Meta
Taxa de escalação correta na primeira tentativa (Tier 1 → Tier certo)	87.4%	91.2%	>90%
Tempo médio até primeira resposta Tier 2 (Sev1)	4.2 min	3.7 min	<5 min
% de Sev1 que tiveram war room convocado em <10 min	92%	96%	>95%
Taxa de re-escalação (mesmo ticket subindo nível 2x ou mais)	8.1%	6.3%	<5%
Pesquisa de satisfação interna (gerente loja após resolução)	4.2/5	4.4/5	>4.0

A queda na taxa de re-escalação (8.1% → 6.3%) reflete dois investimentos: (a) treinamento de Tier 1 em diagnóstico inicial mais robusto (curso interno 16h trimestral), e (b) refinamento do critério de "quando escalar" na regra interna documentada em 17.2 e 17.3.

17.8 Vendor escalation — relacionamentos chave

A Apex mantém relacionamento contratual com cinco vendors prioritários, cada um com TAM (Technical Account Manager) dedicado para escalações fast-track.

Vendor	Tier de contrato	TAM contato	SLA escalation L3
Microsoft	Premier Support (Unified)	Rafael Lima	<2h Sev A · <8h Sev B
Cisco	Smart Net Total Care	Bruno Tanaka	<4h Sev 1 · <24h Sev 2
Fortinet	FortiCare Premium	Carolina Souza	<2h Critical · <8h High
Hikvision	Pro Support BR	Marcos Yamamoto	<8h critical · <48h standard
F5 Networks	Premium Plus	Ana Beatriz Carvalho	<4h Sev 1

Bruno mantém revisão semestral dos TAMs e do uso efetivo de horas Premier — em Q2-2026, o uso Microsoft Premier foi de 62% do contratado, indicando margem para absorver picos sem renegociação contratual.

Página 18 — Template de postmortem + governança

18.1 Template padrão (todo Sev1 + Sev2 selecionados)

O template abaixo é normativo. Postmortems sem todos os campos preenchidos não são aceitos no repositório central.

```
# Postmortem — <título-incidente> · <data>

## 1. Sumário executivo (3-5 linhas)
- O que aconteceu
- Quando começou e quando terminou
- Quantos clientes/lojistas afetados
- Impacto financeiro estimado em R$

## 2. Timeline detalhada
| Hora BRT | Evento | Detector |
|---|---|---|
| ... | ... | ... |

## 3. Análise de causa-raiz (5-whys ou Ishikawa)
1. Por que ...?
2. Por que ...?
...

## 4. Impacto
- Operacional (sistemas afetados, duração)
- Financeiro (R$ perdido, R$ remediation)
- Reputacional (NPS, mídia, redes)
- Regulatório (LGPD, Bacen, ANATEL se aplicável)

## 5. O que funcionou bem
- ...

## 6. O que NÃO funcionou bem
- ...

## 7. Action items + owners + SLA
| AI | Descrição | Owner | SLA | Status |
|---|---|---|---|---|
| AI-1 | ... | ... | ... | ... |

## 8. Lições aprendidas
- ...

## 9. Sign-off
- Incident Commander: <nome>
- CTO: Bruno
- CFO (se aplicável): Carla
- Data publicação: ...
```

18.2 Governança de postmortem

Princípio fundamental: blameless postmortem. O foco é em sistemas e processos, não em culpa individual. A cultura de blame leva a omissão de evidência crítica nos relatos — ninguém quer ficar marcado como "o causador" do incidente. Em compensação, blamelessness exige disciplina rigorosa para que as action items efetivamente resolvam causa-raiz.

Calendário obrigatório:

- **Sev1:** postmortem **obrigatório** publicado em até 5 dias úteis.
- **Sev2:** postmortem **obrigatório** publicado em até 10 dias úteis.
- **Sev3-4:** postmortem **opcional** (a critério do Tier 2 ou Tier 3).

18.3 Repositório centralizado

- **Localização:** Confluence space `Postmortems` (acesso restrito Tier 2+ + lideranças).
- **Naming convention:** `PM-YYYY-MM-DD-<slug-incidente>.md` (e.g., `PM-2025-11-28-blackfriday-apexmoda.md`).
- **Tagging obrigatório:** `severidade`, `domínio` (network/identity/app/data), `marca afetada`, `impacto-R$`.
- **Revisão trimestral** em comitê (Bruno + Marina + DevOps Lead + 1 representante de cada marca afetada) para identificar **tendências sistêmicas** que não aparecem em postmortems individuais.

18.4 Métricas agregadas de incidente (dashboard Bruno)

- **MTBF** (Mean Time Between Failures) por workload — meta: crescente trimestre a trimestre.
- **MTTR** (Mean Time To Resolve) por severidade — meta: decrescente.
- **% de action items dentro do SLA** — meta: >85%.
- **Taxa de incidentes recorrentes** (mesma causa-raiz em <90 dias) — meta: <5%.
- **Custo total de incidentes** trimestral — divulgado em conselho.

18.5 Postmortems publicados Q1-Q2 2026

Data	Incidente	Severidade	Impacto R$	Status AI
28/11/2025	Black Friday apexmoda 47min (TKT-18)	Sev1	R$ 1.870.000	6/6 Done/InProgress no SLA
14/02/2026	VPN Loggi phase-2 down 6h (TKT-20)	Sev2	R$ 47.000 (atrasos last-mile)	4/5 Done
03/03/2026	TMS↔Frota.io webhook silent fail (TKT-15)	Sev2	R$ 38.000 (roteirização manual)	3/3 Done
22/03/2026	Entra ID password notification gap (TKT-17)	Sev3	R$ 0 quantificado (produtividade)	4/4 Done
09/04/2026	CFTV Vila Mariana switch PoE (TKT-16)	Sev3	R$ 0 (compliance interno)	2/3 InProgress

---

18.6 Tendências sistêmicas observadas Q1-Q2 2026

A análise cross-postmortem em comitê trimestral identificou três padrões que mereceram action items estruturais:

Padrão 1 — Autenticação como fonte recorrente de incidente. Três dos cinco postmortems Q1-Q2 2026 (TKT-15, TKT-17, e dois Sev3 menores não listados) tiveram autenticação como causa-raiz. Resposta: programa de aceleração da migração SP → Managed Identity (Q3 prioridade absoluta), curso interno em padrões OIDC + Workload Identity para toda a equipe DevOps + SRE.

Padrão 2 — Capacity ainda não-formalizada em alguns workloads. Black Friday 2025 expôs apexmoda, mas a auditoria do landing zone identificou que ~30% dos workloads críticos ainda não passaram pelo programa de capacity review formalizado em Q1-2026. Resposta: completar a fila em Q3-2026 antes do Black November.

Padrão 3 — Comunicação externa durante incidentes inconsistente. Análise dos 5 postmortems mostrou que o comunicado externo durante a indisponibilidade variou em tom, frequência e canal entre os incidentes. Resposta: criação de playbook de comunicação externa (em construção por Lia + CMO), templates pré-aprovados para 5 cenários comuns (e.g., “site down geral”, “PIX indisponível”, “delay logística”).

18.7 Dependência de postmortems com cross-team

Postmortems da Apex frequentemente envolvem múltiplas equipes — não apenas Tier 2 Network, mas Security, DevOps, SRE, Vendor Management, Legal, Communications. A coordenação entre essas equipes é facilitada por:

1. **Single source of truth no Confluence.** Postmortem master fica em `Postmortems` space; equipes específicas linkam seções de profundidade em seus spaces próprios.
2. **RACI assistance.** O template inclui matriz RACI explícita para cada action item, evitando lacunas de ownership.
3. **Postmortem retrospectives.** Trimestralmente, Bruno conduz reunião de retrospectiva dos postmortems publicados — identifica padrões + ajusta processo.
4. **Cadência regular com fornecedores.** TAMs dos vendors (Microsoft, Cisco, Fortinet, Hikvision, F5) recebem cópia dos postmortems que envolveram seus produtos, dentro do envelope de confidencialidade contratual. Isso alimenta as roadmaps deles + nossa relação técnica.

18.8 Continuous improvement framework

O processo de postmortem alimenta um framework de melhoria contínua estruturado em 4 níveis:

Nível	Frequência	Output	Audiência
L1 — Postmortem individual	Por evento Sev1/Sev2	Documento + action items	Equipe envolvida + lideranças
L2 — Retrospectiva trimestral	Trimestral	Padrões identificados + ajuste processo	Comitê CTO + leads
L3 — Plano anual de reliability	Anual	Roadmap reliability + Capex/Opex	Conselho Executivo
L4 — Benchmark externo	Bienal	Maturidade vs indústria (Gartner peer comparison)	Conselho + CEO

A Apex está atualmente em L2 maduro + L3 em segundo ciclo. L4 (benchmark externo) começa em 2027 quando o programa de reliability completa três anos de maturidade — o consenso da liderança é que comparar antes de ter base sólida geraria conclusões espúrias.

Versão Q2-2026 · próxima revisão Q4-2026. Documento confidencial — uso interno Apex NOC + Tier 2 Network + lideranças. Cross-ref: `manual_operacao_loja_v3.pdf` (procedimentos operacionais de loja física), `runbook_sap_fi_integracao.pdf` (troubleshooting da integração ERP↔Apex),

`politica_dados_lgpd.pdf` (governança de dados em registros de incidente, especialmente quando logs contêm dados pessoais de colaboradores ou clientes).

Owner: Bruno (CTO) · **Maintainer:** Marina (Tier 2 Network Engineer) · **Approver:** Conselho Executivo (revisão semestral).